

Threat Hunting na Prática

da hipótese à detecção, com estudos de caso no Hikari

Sidnei Barbieri Ágney Lopes Roth Ferraz

Instituto Tecnológico de Aeronáutica · Time Hikari

Orientação: Lourenço Alves Pereira Júnior

Só 0,01% dos alertas de um SOC eram ataque

Quatro anos de alertas de rede num SOC em operação:

- **24 a 134 mil** alertas por dia
- **0,01%** ligados a ataques verdadeiros
- **53 dias**, em média, de investigação depois do ataque

A pergunta deste curso

O que acontece com o ataque que **não gerou** nenhum desses alertas?

Yang et al., USENIX Security 2024.

Regras conhecidas podem deixar sinais sem alerta

Detecção

- aplica regras e modelos aos eventos
- produz alertas para padrões definidos
- exige manutenção quando o ambiente muda

Caça

- começa por uma hipótese observável
- investiga sinais sem depender de alerta
- **pode produzir uma detecção candidata**

Critério de sucesso: reduzir a incerteza sobre o ambiente. Uma busca sem resultado restringe a hipótese apenas nas fontes e no período observados.

Cada caso pode ser acompanhado sem computador

Em sala, só com os slides

Leia a hipótese, compare a isca com a evidência e siga cada consulta até a resposta. Os valores e os pivôs aparecem aqui.

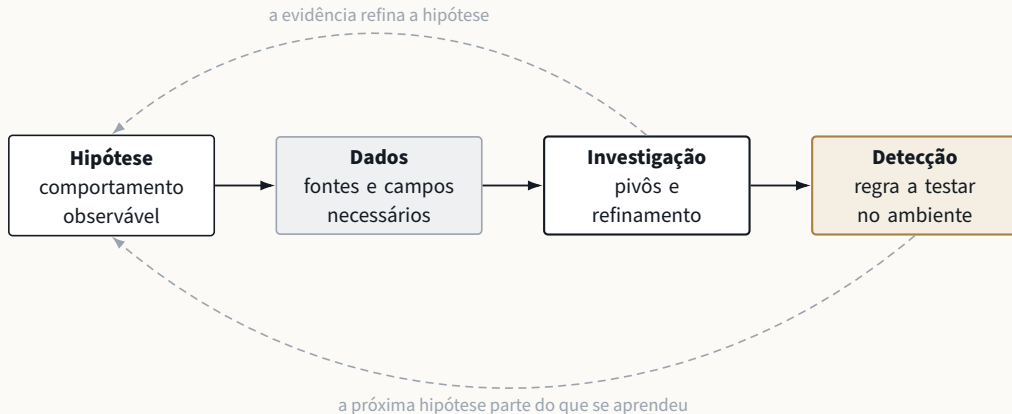
Se houver computador

Refaça as mesmas agregações no caderno. O vídeo mostra a navegação no Hikari isolado e permite revisar o percurso depois.

Método repetido nos três casos: hipótese → filtro → agregação → pivô → conclusão → detecção.

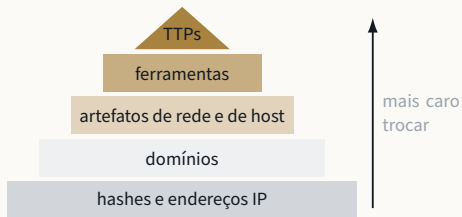
O método

A caçada pode produzir uma regra a validar



Núcleo comum ao PEAK (preparar, executar, agir) e ao TaHiTI (setor financeiro holandês).

Caçar comportamento, porque indicador se troca



Pirâmide da Dor: quanto mais alto o indicador, mais caro para o adversário trocá-lo.

MITRE ATT&CK: táticas (o objetivo) e técnicas (o como) dão vocabulário à hipótese.

As três hipóteses de hoje partem de comportamento. IP, domínio e hash aparecem só como consequência.

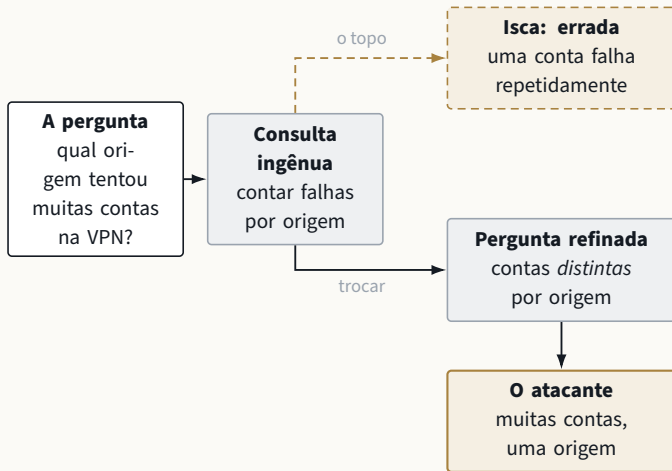
Filtrar com KQL, responder com a agregação

- **ECS:** os mesmos nomes de campo em todas as fontes.
`source.ip user.name host.name event.outcome process.executable`
- **KQL filtra:** `event.dataset:"vpn" and event.outcome:"failure"`
- **A visualização agrega:** contagem, contagem única, soma, ordenação.
- **Pivô:** o valor achado numa fonte vira filtro em outra.

Notação usada nos quadros

`<filtro KQL>` → *a agregação que responde à pergunta*

O fio do curso: a pergunta óbvia cai numa isca



Em cada caso, uma rotina legítima faz a consulta mais óbvia devolver a resposta errada.

Volume é rotina; variedade, regularidade e direção são comportamento.

O que a pesquisa já sabe

Alertas numerosos incluem poucos ataques confirmados

O volume

- 24 a 134 mil alertas por dia, 0,01% ligados a ataque
- praticantes atribuem a maior parte dos falsos positivos a **disparos benignos**: alarme correto, explicado por comportamento legítimo

A organização

- analistas e gestores divergem sobretudo sobre **velocidade e automação**, métricas de avaliação e ferramentas
- o volume de alertas não informa quais sinais ficaram sem regra

Yang et al., USENIX Security 2024 · AlAhmadi, Axon e Martinovic, USENIX Security 2022 · Kokulu et al., CCS 2019.

Entrevistas mostram o peso do conhecimento tácito na caça

- **22 caçadores entrevistados:** três abordagens combinadas, por hipótese, por inteligência e ao acaso; a atividade exige **conhecimento tácito**, e formular a hipótese é uma dificuldade recorrente.
- **Equipes que caçam para órgãos federais dos EUA**, onde a caça é obrigatória: a maioria opera **sem um processo definido**.
- **Quem analisa ameaças persistentes** prioriza entender táticas, técnicas e motivações antes de saber quem está por trás.

Por isso este curso é prático: o conhecimento tácito se transmite executando a caçada, não lendo sobre ela.

Badva et al., USENIX Security 2024 · Maxam e Davis, USENIX Security 2024 · Saha et al., USENIX Security 2025.

Grafos de proveniência ligam eventos, mas exigem interpretação

Reconstruir

O HOLMES relaciona processos, arquivos e conexões para compor uma história de ataque.

Resumir

O DEPCOMM reduz um grafo grande a comunidades que o analista pode examinar.

Atribuir

O ORTHRUS procura tornar a explicação do alerta utilizável na investigação.

O grafo pode indicar vínculos; a equipe ainda precisa testar a explicação diante da telemetria.

Milajerdi et al., S&P 2019 · Xu et al., S&P 2022 · Jiang et al., USENIX Security 2025.

A passagem à operação traz custos e erros

Resultado publicado $\neq$ uso real

- oito sistemas num só arcabouço: **nove deficiências** que dificultam a adoção
- especialistas da indústria os julgam mais eficazes, mas travam no **custo de operação**
- a relutância vem da **qualidade da atribuição**: o esforço para entender o que o detector entrega

O adversário se adapta

- ataques de mimetismo evadiram os **três** detectores avaliados sem mudar o ataque
- quase **metade** de um conjunto de regras de SIEM difundidas é evadida com facilidade

As limitações medidas nesses estudos motivam hipóteses verificáveis e revisão humana dos alertas.

Bilot et al. e Jiang et al., USENIX Security 2025 · Dong et al., CCS 2023 · Goyal et al., NDSS 2023 · Uetz et al., USENIX Security 2024.

Da caçada à regra, sem confiar cegamente na cobertura

- **Sigma:** a lógica da detecção escrita uma vez, convertida para cada SIEM. A regra fica revisável e compartilhável.
- **Num SOC gerenciado**, o jeito como uma regra é desenhada muda de forma significativa a **carga inútil** que ela impõe ao analista.
- **Cobertura de ATT&CK:** muitas técnicas são difíceis, quando não impossíveis, de escrever como regra eficaz, e produtos diferentes anotam **o mesmo comportamento com técnicas diferentes**.

O que ainda depende do caçador

Formular a hipótese, reconhecer a isca e decidir que falso positivo a regra vai aceitar.

A Aurora Telecom

Três dias de uma operadora que não existe

- 120 estações, 5 servidores de aplicação, 2 controladores de domínio, 2 servidores de arquivos
- 9 a 11 de março de 2026, horários em UTC
- **49.277 eventos** no Elastic Common Schema

O ruído foi escolhido para enganar: uma conta que falha repetidamente na VPN, a atualização que todos consultam, o backup de gigabytes e o inventário que enumera grupos a cada dez minutos.

Conjunto	Eventos
dns	22.159
firewall	9.655
fileserver	7.340
edr	4.696
vpn	2.967
auth	2.460

A primeira contagem não responde à hipótese

Uma contagem alta

Uma origem gera 1.440 falhas. O número chama atenção, mas veio de **uma conta só**, sem sessão bem-sucedida.

O comportamento procurado

Outra origem tenta **62 contas** e depois estabelece uma sessão. A combinação responde à hipótese inicial.

Nos três casos, compare a primeira resposta à pergunta formulada. Se a medida não observa o comportamento, refine a agregação antes de seguir.

Leia cada caso em seis decisões

Decisão	Pergunta a responder
Hipótese	Qual comportamento deixaria um sinal observável?
Filtro	Que eventos e período entram na análise?
Agregação	O que precisa ser contado, distinguido ou somado?
Isca	Que rotina legítima explicaria o primeiro resultado?
Pivô	Qual campo registrado liga esta etapa à próxima?
Conclusão	O que os eventos mostram, e o que ainda não mostram?

Os próximos slides trazem os valores e vínculos de cada caso. O caderno permite recalcular as agregações; as aulas narradas permitem revê-las.

Caso 1 • Da força bruta ao privilégio

Hipótese: uma origem tenta muitas contas e uma delas cede

Hipótese

Uma origem externa produz falhas em **muitas contas diferentes** e depois estabelece uma sessão. Que eventos ligam essa sessão à atividade no servidor?

T1133 External Remote Services · T1110 Brute Force · T1078 Valid Accounts · T1021.001 RDP
· T1136.001 Create Local Account

Quem mais falha é a sonda; quem tenta mais contas é o ataque

`event.dataset:"vpn" and event.outcome:"failure"` → *falhas e contas distintas por origem*

Origem	Falhas	Contas distintas	Entrou?
10.20.5.14	1.440	1	não
203.0.113.77	1.026	62	sim
177.39.199.144	2	2	sim

Isca: `monitor.vpn` falha repetidamente numa conta; os eventos não mostram a causa. A pergunta certa é “**quantas contas cada origem tentou**”.

Do endereço da VPN ao novo administrador, em 14 minutos

1. `source.ip:"203.0.113.77"` and
`event.outcome:"success"`
sessão como **c.moura**; a VPN atribui 10.8.200.23

2. Pivô no **endereço**, não na conta:

`event.dataset:"auth"` and
`source.ip:"10.8.200.23"`
logon remoto em **SRV-FIN-02**

3. `host.name:"SRV-FIN-02"` and
`event.code:("4720" or "4732")`
conta **svc_relatorios** criada e posta em
Administradores

UTC, 10/03

04:10:03	primeira falha
05:17:40	última de 1.026 falhas
05:17:43	sessão estabelecida
05:24:10	RDP em SRV-FIN-02
05:30:48	conta criada
05:31:35	administrador

Caso 1 • refaça a investigação do início ao fim

1. Filtre `event.dataset:"vpn"` and `event.outcome:"failure"`. Agrupe por `source.ip`; conte falhas e contas únicas.
2. Descarte o topo por volume: `10.20.5.14` tem 1.440 falhas numa conta. Investigue **203.0.113.77**: 1.026 falhas em 62 contas.
3. Na mesma origem, filtre `event.outcome:"success"`. A sessão de `c.moura` às 05:17:43 recebe `client.nat.ip:10.8.200.23`.
4. Busque esse IP em `event.dataset:"auth"`. O login tipo 10 leva a SRV-FIN-02; eventos 4720 e 4732 mostram `svc_relatorios` criada e adicionada a Administradores.

Resposta sustentada pelos eventos

A origem externa é **203.0.113.77**. O IP da VPN liga a entrada à persistência; a causa das falhas de `monitor.vpn` permanece desconhecida.

A regra que fica não cita o IP do atacante

Muitas contas falhando a partir da mesma origem, seguidas de sucesso

condition: falhas | count(distinct user.name) by source.ip > 15 in 1h
followed by sucesso from the same source.ip in 1h
falsepositives: NAT compartilhado com poucos usuários

- 203.0.113.77 não aparece: o adversário troca de endereço em minutos.
- Segunda regra, menos ruidosa: conta criada e posta em grupo administrativo pela mesma sessão, em minutos.

Prática 1 • a origem do acesso à VPN (25 min)

Sem computador • resolva pela tabela

1. Compare 1.440 falhas em uma conta com 1.026 em 62 contas.
2. Qual origem tem sucesso? Qual IP interno ela recebe?
3. Onde esse IP reaparece, e que privilégio foi criado?

Com computador • refaça e confira

1. caso1.ipynb: agrupe falhas e contas distintas.
2. Use os filtros do slide anterior no Hikari isolado.
3. Veja o vídeo do caso para revisar os pivôs.

A resposta e os horários estão nos slides anteriores; o caderno e o vídeo permitem repetir o percurso.

Caso 2 • O canal que respira

Hipótese: um implante pede ordens com regularidade

Hipótese

Um implante que pede ordens a um servidor externo gera consultas **regulares** a um domínio que **quase ninguém mais** na empresa consulta.

T1071.001 Web Protocols · T1036.005 Match Legitimate Name · T1204.002 Malicious File ·
T1041 Exfiltration

O domínio mais consultado é a atualização; o canal tem uma estação só

`event.dataset:"dns"` → *consultas e estações distintas por nome*

Domínio	Consultas	Estações
update.aurora.com.br	8.640	120
api.whatsapp.com	1.109	120
telemetria-aurora-cdn.net	719	1
fornecedor-cabos.com.br	3	1

Na estação WKS-ENG-117:

- canal: intervalos de **285 a 315 s**, mediana 300, madrugadas incluídas
- atualização legítima: de 372 a 6.951 s

A pergunta certa junta frequência e raridade: muito consultado, e por uma estação só.

O nome engana; caminho, hash e processo pai não

host.name:"WKS-ENG-117" and process.name:"OneDriveUpdater.exe"

360 execuções legítimas

- C:\Program Files\Microsoft OneDrive\
- pai: OneDrive.exe
- mesmo hash em todas as estações

1 execução

- C:\Users\r.lemos\AppData\Roaming\
- pai: **WINWORD.EXE**
- outro hash

O Word abriu Reajuste_Contratos_2026.docm às 12:12:30 de 09/03; o implante começou 41 segundos depois.

O volume enviado aparece somando na direção certa

Isca 1: o maior fluxo isolado, 8,8 GB, é o backup para 10.30.0.10, **interno**.

Isca 2: somar bytes **recebidos** aponta o espelho de atualização, 22,7 GB de download.

`not destination.ip:"10.0.0.0/8" → soma de source.bytes por destino`

198.51.100.61: 2.292.933.770 bytes enviados
180 fluxos de 11 a 14,5 MB, de 01:05 a 02:37 de 10/03

Por que ninguém viu

A soma mede tráfego enviado ao destino. O fluxo não mostra que conteúdo saiu. O canal existia havia **mais de 12 horas**.

Caso 2 • siga do DNS ao volume enviado

1. Em `event.dataset:"dns"`, conte consultas e *estações distintas* por `dns.question.name`.
`update.aurora.com.br` tem 8.640 consultas em 120 estações; **telemetria-aurora-cdn.net**, 719 em uma.
2. Filtre o domínio e ordene por tempo: intervalos de 285 a 315 segundos, inclusive à noite. A estação é `WKS-ENG-117`.
3. Em `event.dataset:"edr" and host.name:"WKS-ENG-117"`, compare o executável: `OneDriveUpdater.exe` em `AppData`, filho de `WINWORD.EXE`, difere do instalado em `Program Files`.
4. Em `event.dataset:"firewall"`, exclua destinos internos e some `source.bytes` por destino.
198.51.100.61 recebeu 2.292.933.770 bytes em 180 fluxos; o backup de 8,8 GB era interno.

Conclusão sustentada pelos eventos

A estação **WKS-ENG-117** manteve um canal periódico e enviou cerca de **2,293 GB** ao destino externo. O fluxo não revela o conteúdo enviado.

Prática 2 · o canal que respira (25 min)

Sem computador · siga as evidências

1. Qual domínio combina regularidade com uma estação só?
2. Que caminho e processo pai distinguem o executável?
3. Qual destino recebeu os bytes enviados?

Com computador · refaça e confira

1. `caso2.ipynb`: domínio, intervalos e soma.
2. Busque a estação no Hikari isolado.
3. Veja o vídeo para revisar os três pivôs.

O maior fluxo isolado e o maior volume recebido apontam rotinas diferentes; a hipótese pede bytes enviados para fora.

Caso 3 · Do mapa do diretório ao impacto

Hipótese: a enumeração pode anteceder o impacto

Hipótese

No cenário, a conta usada no incidente enumera **muitos grupos em pouco tempo**, fora da rotina de inventário, e o movimento lateral vem logo depois.

T1069.002 Domain Groups · T1569.002 Service Execution · T1490 Inhibit System Recovery ·
impacto simulado por renomeações

O inventário enumera mais; o invasor enumera mais largo

`event.dataset:"auth" and event.code:"4799"` → *eventos e grupos distintos por conta*

Conta	Eventos 4799	Grupos distintos
svc_inventario	1.296	3
adm.backup	61	47

Isca: o inventário confere os mesmos 3 grupos a cada dez minutos.

adm.backup percorre 47 grupos em **6 minutos**. Pivô: `host.ip:"10.40.0.140"` →

WKS-ADM-104.

Do mapa às renomeações em cerca de 26 minutos

UTC, 10/03	Evento
16:40–16:46	enumeração: 61 consultas, 47 grupos
17:05:00	logon de rede no FS01
17:05:09	serviço PSEXESVC instalado
17:05:14	aurora_upd.exe em Windows\Temp
17:05:31	vssadmin delete shadows
17:05:45	primeiro arquivo .aurora-lock
17:14:45	a mesma sequência no FS02
17:30:42	último de 3.420 arquivos

Isca: o agente de backup renomeia de 518 a 615 arquivos por dia.

Separe pela **extensão nova**, não pela contagem de renomeações.

Caso 3 · volte do impacto ao primeiro sinal

1. Em `event.dataset:"fileserver"`, agrupe renomeações por `file.extension`. `bak` é rotina; **aurora-lock** aparece em 3.420 arquivos de FS01 e FS02.
2. Volte ao `event.code:"4799"`: conte *grupos distintos* por `user.name.svc_inventario` consulta 3 grupos; **adm.backup**, 47 em seis minutos.
3. O `source.ip:10.40.0.140` leva à WKS-ADM-104. Logons tipo 3 da mesma conta chegam a FS01; o EDR mostra `PSEXESVC` e `vssadmin delete shadows`.
4. Compare horários: enumeração às 16:40:03; primeira extensão `aurora-lock` às 17:05:45.

Conclusão sustentada pelos eventos

A enumeração deu cerca de **26 minutos** antes da primeira renomeação para `aurora-lock`; o log não prova o conteúdo cifrado.

A regra que teria dado tempo mira o começo da cadeia

Enumeração ampla fora do inventário

```
condition: event.code: 4799 and not user.name: svc_inventario  
          | count(distinct group.name) by user.name > 20 within 15m
```

Cópias de sombra apagadas

```
process.command_line|contains|all: [vssadmin, delete, shadows]  
level: critical
```

A caçada chegou tarde: a enumeração deu 26 minutos de janela. A regra derivada transforma essa janela em alerta.

Prática 3 • do mapa do diretório ao impacto (20 min)

Sem computador • reconstrua a cadeia

1. Que extensão distingue a sequência suspeita do backup?
2. Qual conta consultou 47 grupos? De qual estação?
3. Quanto tempo separa a enumeração das primeiras renomeações?

Com computador • refaça e confira

1. `caso3.ipynb`: grupos distintos e horários.
2. Siga a conta no Hikari isolado.
3. Veja o vídeo e proponha uma regra para 4799.

A resposta está nos slides anteriores; discuta também o falso positivo de uma administração legítima.

Levar para o trabalho

Os três casos têm o mesmo desenho

	Caso 1	Caso 2	Caso 3
A pergunta óbvia	quem mais falha	o maior fluxo	quem mais enumera
A isca	sonda de monitoramento	backup e atualização	inventário
A pergunta certa	quantas contas	com que regularidade, em que direção	quão largo
O pivô	endereço da VPN	estação e processo	endereço de origem

Hipótese sobre **comportamento**; a primeira agregação errada, e isso é esperado; cada pivô sustentado por **um vínculo nos eventos**; o resultado pode ser uma **regra a validar**.

Transfira o método, não os limiares

O que o cenário ensina

Contrastar hipóteses com rotinas legítimas, justificar cada pivô e explicitar a evidência que falta.

O que precisa ser medido de novo

Distribuições locais, cobertura das fontes, falsos positivos, relógios e custo de responder a cada alerta.

Uma regra derivada de um caso sintético é uma candidata: teste-a no histórico antes de ativá-la.

O que vem: modelos de linguagem, com a mesma desconfiança

- Um modelo leve, com ajuste fino, recuperação e planejamento, planejou respostas a incidentes com recuperação **até 22% mais rápida** que modelos de fronteira, e com probabilidade de alucinação limitada **sob as premissas que os autores declaram**.
- A caça pode ganhar o mesmo apoio para propor hipóteses e consultas.
- A conclusão continua precisando ser conferida contra a evidência, **como fizemos em cada caso**.

Limites deste material: cenário sintético e limpo; ambientes reais têm campos ausentes, relógios fora de sincronia e ruído maior. As regras ilustram a lógica; produção exige ajuste.

Hammar, Alpcan e Lupu, NDSS 2026.

**Agora escreva as hipóteses
do seu ambiente.**

`hikari-edu.github.io/minicurso`

Sidnei: `sidneibarbieri@gmail.com`

Roth: `agneyroth@gmail.com`